

Comunicación "A" 7890 — Lineamientos para la gestión de riesgos de tecnología y seguridad

Banco Central de la República Argentina. A las entidades financieras.

La presente deroga la Comunicación "A" 6641 y sus modificatorias, cuyas disposiciones quedan sin efecto a partir de la entrada en vigencia de esta norma.

1. Objeto

Establecer los lineamientos mínimos para la gestión de los riesgos de tecnología de la información y de seguridad de la información, incluyendo la ciberseguridad y la continuidad operativa.

2. Gobierno

El Directorio de la entidad es responsable de aprobar la estrategia de gestión de riesgos de tecnología y de asignar los recursos necesarios. La entidad designará un responsable de seguridad de la información con dependencia funcional independiente del área que administra la tecnología.

3. Segregación de funciones

Las funciones de desarrollo, operación y control de los sistemas se asignarán a personas o unidades distintas. Quien administra los privilegios de acceso a un sistema no podrá ser quien audita esos privilegios.

4. Gestión de accesos

Las entidades implementarán controles de acceso basados en el principio de mínimo privilegio y necesidad de conocer. Los accesos con privilegios elevados serán nominales, tendrán vigencia acotada y estarán sujetos a revisión periódica documentada. El uso de credenciales compartidas para funciones administrativas no resulta admisible.

5. Registro de eventos

Las entidades registrarán los eventos relevantes de seguridad de forma que su integridad no pueda ser comprometida por quienes administran los sistemas registrados. Los registros se conservarán por el plazo aplicable a la documentación de auditoría.

6. Gestión de incidentes

Las entidades contarán con procedimientos de detección, respuesta y recuperación ante incidentes de seguridad, y notificarán al Banco Central los incidentes de significatividad conforme a los plazos y al régimen informativo aplicable.

7. Continuidad operativa

Las entidades definirán objetivos de tiempo de recuperación y de pérdida máxima de información admisible para cada servicio, y probarán sus planes de continuidad con periodicidad no menor a la anual, con participación de las áreas de negocio.

8. Servicios provistos por terceros

La delegación de procesos o servicios en terceros no relevará a la entidad de su responsabilidad. Los contratos deberán prever el derecho de acceso y auditoría de la entidad y de este Banco Central, la notificación de incidentes y las condiciones de recuperación de la información a la finalización del servicio.